Microsoft 365 — Configurar MFA

Categoria: Microsoft 365 / Segurança / Identidades
Sistema: Microsoft 365 / Microsoft Entra ID
Tipo: Administração / Segurança / Autenticação
Nível: Intermediário

Objetivo

Orientar como configurar, habilitar e validar a autenticação multifator (MFA) para usuários do Microsoft 365, reduzindo riscos de acesso não autorizado.

Conceito

A MFA exige mais de um fator de autenticação: conhecimento (senha), posse (aplicativo ou chave de segurança) ou inerência (biometria). O Microsoft Entra ID gerencia os métodos e políticas de autenticação.

• Métodos possíveis: Microsoft Authenticator, chaves FIDO2, Windows Hello for Business, aplicativos autenticadores e, quando permitidos, SMS ou chamadas.

• A exigência de MFA pode ocorrer por Security Defaults, Acesso Condicional ou MFA por usuário (legado).

• Exemplo: joao.silva@contabilprime.com.br registra o Microsoft Authenticator para acessar recursos corporativos.

Procedimento

01. Verificar os pré-requisitos

Confirme conta ativa, permissões administrativas, políticas existentes, métodos permitidos, licenciamento e procedimentos de recuperação. Acesso Condicional geralmente exige Microsoft Entra ID P1 ou licença equivalente.

02. Acessar o Microsoft Entra Admin Center

Entre em entra.microsoft.com com uma conta administrativa autorizada.

03. Verificar Security Defaults

Em Entra ID → Overview → Properties → Manage security defaults, verifique se os padrões de segurança estão habilitados. Eles se aplicam ao ambiente, não individualmente.

04. Consultar Acesso Condicional

Em Entra ID → Conditional Access → Policies, revise políticas existentes e avalie impactos sobre usuários, administradores, aplicativos e contas de serviço.

05. Criar política de MFA

Selecione New policy e nomeie CA - Exigir MFA - Usuarios Corporativos. Em Users, escolha inicialmente um grupo piloto; em Target resources, escolha os recursos; em Grant, exija MFA.

06. Configurar exclusões

Avalie a exclusão de contas de emergência, com monitoramento e controles compensatórios. Evite exclusões amplas sem justificativa.

07. Testar a política

Configure Report-only e analise os resultados nos logs de autenticação antes de aplicar a política.

08. Habilitar a política

Após testes e aprovação, altere o estado da política para On, salve e monitore os registros.

09. Registrar método de autenticação

Oriente o usuário a acessar mysignins.microsoft.com/security-info → Add sign-in method → Microsoft Authenticator, ou outro método permitido, e concluir o registro.

10. Validar o acesso

Solicite nova autenticação em um recurso abrangido e confirme o desafio de MFA e o acesso autorizado.

Comandos PowerShell

Instalar o SDK Microsoft Graph e conectar com permissões apropriadas:

```
Install-Module Microsoft.Graph -Scope CurrentUser
Connect-MgGraph -Scopes "User.Read.All", `
  "UserAuthenticationMethod.Read.All"
```

Consultar a conta e os métodos registrados:

```
Get-MgUser -UserId "joao.silva@contabilprime.com.br" `
  -Property DisplayName,UserPrincipalName,AccountEnabled
Get-MgUserAuthenticationMethod `
  -UserId "joao.silva@contabilprime.com.br"
```

Ter métodos registrados não comprova que a política esteja exigindo MFA.

Validação

• Confira o método registrado no perfil do usuário no Microsoft Entra.

• Confirme que a política está habilitada e abrange usuário e recurso.

• Em Entra ID → Monitoring & health → Sign-in logs, confira Authentication details e Conditional Access.

• Teste o acesso real e confirme o desafio de MFA.

Observações

• Priorize métodos resistentes a phishing; evite depender exclusivamente de SMS.

• Teste em grupo piloto antes da aplicação geral.

• Proteja e monitore contas de emergência.

• Planeje recuperação de acesso e não desabilite MFA sem análise de risco.

• Documente mudanças e verifique requisitos de licença.

Resultado esperado

Usuários abrangidos deverão realizar autenticação multifator conforme a política: credenciais → avaliação de política → segundo fator → acesso autorizado.